

NOTE AU COMITÉ DE DIRECTION

Finexa (exemple)

Infrastructure numérique · Finexa SAS · SIREN 000 000 000 · Établi par Consultant du cabinet · À l'attention de Thomas Lefèvre, directeur général délégué · Établie le 24 septembre 2026

5 textes s'appliquent (RGPD, NIS2 (ReCyF), DORA, CRA, AI Act), soit 40 exigences unifiées. Couverture déclarée : 46 % ; 9 exigences sans aucune mesure, 17 partiellement couvertes.

TEXTES APPLICABLES

5 / 5

RGPD · NIS2 (ReCyF) ·
DORA · CRA · AI Act

COUVERTURE

46 %

36 / 40 exigences évaluées

SANS AUCUNE MESURE

9

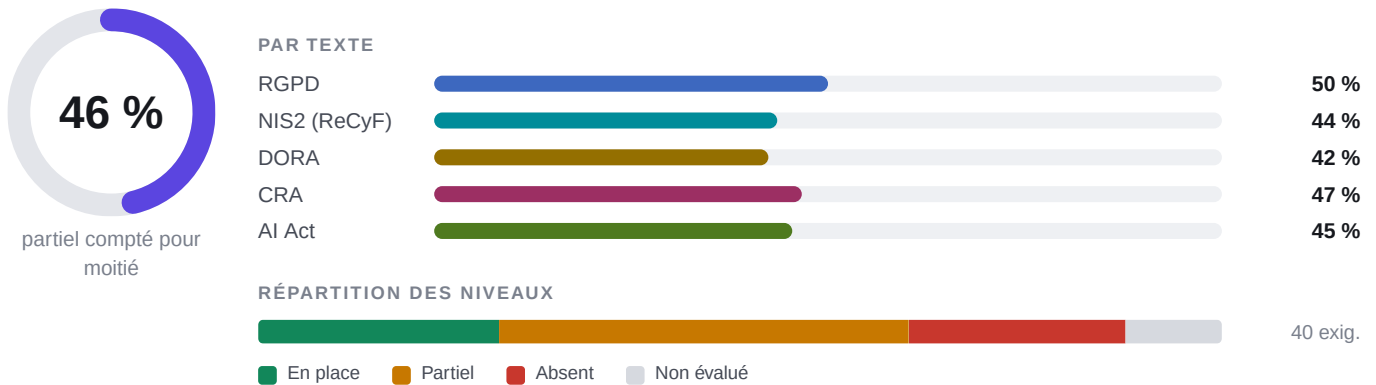
exigences unifiées

SANCTION MAXIMALE

20 M€

Plafond RGPD

Où en est-on



Ce qui nous expose

TEXTE	QUALIFICATION RETENUE	COUVERTURE	SANCTION PLAFOND
RGPD	Responsable soumis à désignation d'un délégué	50 %	20 M€
NIS2 (ReCyF)	Entité importante	44 %	7 M€
DORA	Entité financière	42 %	Régime national
CRA	Fabricant, produit par défaut	47 %	15 M€
AI Act	Déploreur, risque limité	45 %	900 k€

Par quoi commencer

- Responsabilité de l'organe de direction** RGPD + NIS2 (ReCyF) + DORA + AI Act
 Instituer une instance de gouvernance unique (comité sécurité et conformité) qui approuve formellement les politiques, suit les indicateurs et consigne ses décisions. Une seule délibération, correctement rédigée, vaut approbation au titre des trois textes.
 Aujourd'hui : absent · Porteur : Direction générale · Charge 3/5
- Corpus documentaire et politiques** RGPD + NIS2 (ReCyF) + DORA + CRA + AI Act
 Constituer un corpus unique, avec une politique cadre et des politiques thématiques, chacune portant une table de correspondance vers les articles qu'elle satisfait. C'est cette table qui transforme un document interne en preuve de conformité.
 Aujourd'hui : absent · Porteur : Conformité · Charge 3/5

3

Notification des incidents à l'autorité

Établir une matrice de notification unique (événement, qualification, autorité, délai, modèle, responsable) et la répéter en exercice. L'horloge la plus courte commande la mobilisation de la cellule de crise, même si les autres délais sont plus longs.

Aujourd'hui : absent · Porteur : RSSI · Charge 4/5

RGPD + NIS2 (ReCyF) + DORA + CRA + AI Act

Feuille de route

Vague 1 · 0 à 3 mois	Vague 2 · 3 à 6 mois	Vague 3 · 6 à 12 mois	Vague 4 · Au-delà de 12 mois
4 exigences	6 exigences	8 exigences	22 exigences
· Responsabilité de l'organe de direction	· Registre et cartographie des tiers	· Registres réglementaires	· Gestion des identités et des accès
· Corpus documentaire et politiques	· Tests, exercices et audits	· Fonction dédiée et point de contact	· Sécurité par conception, développement et changements
· Notification des incidents à l'autorité et 1 autres	· Lex specialis : DORA prime sur NIS2 et 3 autres	· Formation et sensibilisation et 5 autres	· Détection et supervision de sécurité et 19 autres

Où sont les faiblesses

Gouvernance		30 %	Résilience		10 %
Risques		50 %	Tiers		25 %
Protection		75 %	Données		100 %
Détection		67 %	Intelligence artificielle		50 %
Réponse		33 %	Documentation		17 %

Décisions attendues

- Valider la vague 1 (4 exigences, 0 à 3 mois) et le budget associé.
- Désigner un responsable pour 10 exigences en écart sans porteur identifié.
- Faire compléter l'évaluation : 4 exigences restent à évaluer.
- Lever 1 point resté à vérifier lors du cadrage (voir l'annexe du rapport complet).
- Arbitrer 1 exigence obligatoire dont le contrôle ISO 27001 correspondant a été exclu de la démarche.
- Suivre l'adoption de la loi de transposition de NIS2 et arrêter le calendrier de mise en conformité qui en découlera.

PROCHAINES ÉCHÉANCES		SI UN INCIDENT SURVENAIT	
7 octobre 2026	Examen du projet de loi résilience à l'Assemblée nationale	RGPD	CNIL · dès 72 h
2 décembre 2026	Nouvelle interdiction et fin du délai de marquage	NIS2 (ReCyF)	Notifié au titre de DORA
31 décembre 2026	Promulgation attendue de la loi résilience	DORA	ACPR · dès 4 h
		CRA	ENISA · dès 24 h
		AI Act	Autorité de surveillance du marché · dès 2 j

Arbitrages du comité

N°	DÉCISION PRISE	PORTEUR	ÉCHÉANCE
1			
2			
3			
4			
Date du comité : _____ Présenté par : _____			

Établie à partir des éléments déclarés et de l'état du droit à la date indiquée. Elle ne remplace ni l'analyse d'un conseil, ni la position de l'autorité compétente. Détail, fondements et méthode : rapport de cadrage complet.